@demotoprod · EDGE

Edge AI security checklist

On 17 Sep 2026 a group reported unbolting one licence-plate-reader camera and finding the encryption key next to the recorded media: about 1.6 million images and 27,321 clips from roughly 21 days, from a device whose vendor had said footage is only briefly stored. A device that scores frames locally must decrypt them locally, so "encrypted at rest" protects a dead disk, not a working device.

1 Pull one unit off the wall and count what is on it

The claim was "briefly stored"; the device held about 21 days of media, and nobody knew because nobody had taken a unit down and counted. Retention on the edge is a claim until someone counts, and the count is what a thief gets.

- Once a quarter, image one deployed device per hardware revision and list every file with its age.
- Put the counted retention in the questionnaire; set the on-device window in minutes and alert past it.

2 Keep keys in a secure element the board cannot read as a file

The stolen camera's media partition carried the key that unlocked the media, so on-device encryption changed nothing for whoever held it. The consumer IoT baseline standard says sensitive security parameters shall be stored securely and a per-device identity shall resist physical, electrical and software tampering.

- Per-device keys in a secure element or TEE, generated on the device, never on flash; no shared fleet key.
- The cloud accepts a device only after attestation; "encrypted at rest" is true only when the device is off.

3 Store the result, not the frame

The model needed each frame for milliseconds; the device kept it for weeks. About 50,200 vehicles and 11 people were in the extracted media because raw frames stayed after the inference that used them. The NIST core baseline makes data protection a capability of the device itself.

- Write the inference output (class, count, score) and at most a thumbnail; drop the frame after scoring.
- Anything waiting for upload is encrypted with a key the device does not hold; delete on acknowledgement.

4 Sign the model and the firmware, and refuse anything unsigned

A device nobody guards can be opened, re-flashed and put back, so the model and the firmware must prove where they came from. The baseline standard asks for secure boot and updatable software; UK law for consumer connectable products (in force 29 April 2024) requires a published minimum security-update period.

- Secure boot with anti-rollback; the model is signed with a key that never lives on the device, and an unsigned model does not load.
- Signed over-the-air updates with a tested rollback; publish the support period per hardware revision.

5 Rehearse losing the box

One unit gave up 21 days of media; with a shared key it would have been the fleet. The NIST baseline asks that each device be uniquely identifiable and report its own state, which helps only if revoking one has been rehearsed.

- Per-device identity and certificate, and a "reported stolen" runbook that revokes it within minutes.
- Remote wipe on next contact; rehearse the runbook on a real unit twice a year.